

Chapitre 3

La mesure et l'évaluation des risques

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Les données de pertes : cercles concentriques, seuils réglementaires et événements frontiers

- (a) En 2000, ING a représenté son cadre de gestion du risque opérationnel comme quatre cercles concentriques, où « la base de données de pertes [est] au centre, alimentant les auto-évaluations (RCSA) au deuxième cercle, elles-mêmes surveillées par des indicateurs clés de risque (KRI) au troisième cercle, et complétées par les leçons apprises des incidents majeurs au cercle extérieur ». Décrire, cercle par cercle, ce qui fait que chaque cercle *s'alimente* du cercle qu'il entoure ou le *surveille*. Pourquoi, selon cette représentation, la base de données de pertes occupe-t-elle nécessairement le centre du schéma plutôt que la RCSA ou les KRI ?
- (b) Le cours indique que « le BCBS exige, sous l'approche standardisée, un historique de dix ans de données, un seuil minimal de collecte de 20 000 euros, le rattachement de chaque perte interne aux catégories d'événements de Bâle, l'enregistrement des dates de survenue et de récupération, et une revue indépendante de l'exhaustivité et de l'exactitude des données de pertes », tout en précisant qu'« en pratique, de nombreux établissements retiennent des seuils plus bas (1 000 à 5 000 dollars, livres ou euros) pour ne pas perdre d'information utile à la gestion ». Pourquoi un seuil de collecte interne inférieur au seuil réglementaire peut-il servir la gestion du risque, alors même que les pertes ainsi collectées ne comptent pas pour le calcul du capital minimal ? Le cours ajoute que « la tendance récente [est] de relever ces seuils pour éviter la surcharge de déclaration » : quelle tension cela révèle-t-il entre exhaustivité de la collecte et charge opérationnelle de sa gestion ?
- (c) Un « événement frontière » (boundary event) « se matérialise dans une catégorie de risque différente de sa cause », par exemple « une perte de crédit aggravée par une erreur d'enregistrement du collatéral ». Le cours précise que « les pertes opérationnelles liées au risque de crédit et déjà comptées dans les actifs pondérés de crédit doivent être exclues de la base de pertes opérationnelles, tandis que celles liées au risque de marché restent traitées comme risque opérationnel aux fins du calcul du capital minimal ». Pourquoi ce traitement est-il asymétrique entre les deux cas — pourquoi exclure l'un et pas l'autre de la base de pertes opérationnelles ? Quel principe de non double-comptage du capital réglementaire cette asymétrie cherche-t-elle précisément à préserver ?
- (d) Le cours impose un « jeu minimal de champs structurés » pour chaque incident enregistré, en insistant que « le texte libre, utile pour la narration, ne doit jamais remplacer les champs structurés au risque de rendre l'analyse et l'agrégation automatisées impossibles ». Il ajoute que « le grand livre général, les journaux d'incidents informatiques (priorités P1/P2), les provisions pour litiges, les réclamations clients et la presse négative servent de sources croisées » pour vérifier l'exhaustivité de la collecte, la « sous-déclaration restant un défi persistant, en particulier pour les petits établissements ». Pourquoi le texte libre, malgré son utilité narrative, compromet-il spécifiquement l'agrégation automatisée plutôt que la seule compréhension d'un incident pris isolément ? En quoi le recours à des sources externes à la base d'incidents elle-même (grand livre, journaux P1/P2, etc.) constitue-t-il un contrôle de *cohérence* plutôt qu'une simple source additionnelle de données ?

Exercice 2 — L'évaluation qualitative : RCSA, carte de chaleur et indicateurs

- (a) La RCSA « évalue la probabilité et l'impact d'un risque avant l'effet des contrôles en place (risque inhérent) et après (risque résiduel) », sur des échelles comportant « quatre dimensions — financière, réglementaire, client, réputationnelle », de plus en plus souvent « exprimées en pourcentage du chiffre d'affaires ou des clients, pour rester comparables entre entités de tailles différentes ». Pourquoi la distinction entre risque inhérent et risque résiduel est-elle indispensable pour juger de l'efficacité réelle d'un dispositif de contrôle, plutôt que de se contenter d'une seule mesure du risque ? En quoi exprimer l'impact en pourcentage du chiffre d'affaires plutôt qu'en valeur absolue résout-il un problème de comparabilité entre, par exemple, une petite agence régionale et une grande banque internationale ?

- (b) Le cours met en garde : « une erreur répandue consiste à multiplier une note de probabilité par une note d'impact pour produire un score numérique unique [...] un risque fréquent à faible impact (1×4) n'est pas équivalent à un risque rare à impact extrême (4×1), bien que le produit soit identique ». Expliquer, en termes de gestion du risque, pourquoi un risque « fréquent à faible impact » appelle un mode de traitement (contrôles préventifs de routine, budgets d'exploitation courants) fondamentalement différent d'un risque « rare à impact extrême » (plans de continuité d'activité, capital de réserve), alors même que leur produit arithmétique $1 \times 4 = 4 \times 1$ est strictement identique.
- (c) La carte de chaleur combine probabilité et impact en un code à quatre couleurs : « vert (dans l'appétit, surveillance de routine), jaune (dans l'appétit mais en approche de la limite), ambre (au-dessus des niveaux acceptables, plan d'action requis), rouge (bien au-delà de l'appétit, action urgente requise) ». Décrire ce qui distingue précisément, en termes d'action attendue de la part du management, chacune des quatre couleurs. Pourquoi une carte de chaleur qui ne comporterait que deux couleurs (« acceptable » / « inacceptable ») perdrait-elle une information de gestion utile que le code à quatre couleurs préserve, en particulier la distinction entre le jaune et le rouge ?
- (d) Le cours distingue trois familles d'indicateurs : les « KPI (indicateurs clés de performance) [qui] mesurent l'atteinte d'objectifs opérationnels », les « KRI (indicateurs clés de risque) [qui] signalent l'évolution de la probabilité ou de l'impact d'un risque » — par exemple « une hausse du nombre de transactions par employé (risque d'erreur) ou une baisse de la satisfaction client (risque d'attrition) » —, et les « KCI (indicateurs clés de contrôle) [qui] mesurent l'efficacité de conception ou de fonctionnement des contrôles », le cours précisant que « ces trois familles se recoupent largement : une défaillance de contrôle est simultanément un KPI dégradé, un KRI d'alerte et un KCI en échec ». Construire un exemple concret, différent des deux exemples de KRI déjà donnés par le cours, où un même événement observable serait simultanément lisible comme un KPI dégradé, un KRI d'alerte et un KCI en échec, en identifiant précisément ce qui, dans votre exemple, joue le rôle de chacun des trois indicateurs.

Exercice 3 — Les modèles factoriels et la modélisation statistique (LDA)

- (a) Les modèles factoriels « décomposent un scénario de risque en ses facteurs constitutifs de probabilité et d'impact, augmentant la robustesse et la transparence de l'estimation par rapport à un jugement global ». L'exemple du cours décompose une fuite de données par un initié en cinq conditions : « une cyberattaque ciblée par hameçonnage (P1), l'échec du pare-feu (P2), l'ouverture du courriel par un employé (P3), l'échec des contrôles détectifs de surveillance réseau (P4), et la sortie effective de l'information (P5) », la probabilité conjointe de ces cinq conditions — « éventuellement ajustée par des probabilités conditionnelles bayésiennes lorsque les facteurs ne sont pas indépendants » — donnant la probabilité du scénario complet. Pourquoi la décomposition en cinq facteurs distincts rend-elle l'estimation « plus robuste et plus transparente » qu'un jugement d'expert global portant directement sur la probabilité de l'ensemble du scénario ? Donner un exemple concret de deux de ces cinq conditions qui ne seraient manifestement *pas* indépendantes l'une de l'autre, et expliquer pourquoi ignorer cette dépendance biaiserait le calcul de la probabilité conjointe.
- (b) Popularisé par le psychologue James Reason, le modèle du « fromage suisse » « représente chaque couche de défense comme une tranche de fromage suisse percée de trous mouvants. Un incident grave ne survient que lorsque les trous de plusieurs couches s'alignent momentanément », la leçon étant que « l'indépendance des défaillances de contrôles entre elles importe au moins autant que la fiabilité de chaque contrôle pris isolément ». Expliquer précisément pourquoi deux couches de défense chacune fiable à 95 % mais dont les défaillances sont fortement corrélées (par exemple deux contrôles qui reposent sur le même système informatique sous-jacent) offrent une protection combinée bien inférieure à ce que suggérerait le simple produit de leurs taux de défaillance individuels.
- (c) L'outil du « nœud papillon » (bowtie) « place l'événement de risque au centre, ses causes

directes et indirectes à gauche (avec les contrôles préventifs), et ses impacts directs et indirects à droite (avec les contrôles détectifs et correctifs) ». La technique du « 5 pourquoi » « permet de remonter jusqu'à la cause racine d'un incident, par exemple une mise à jour de sécurité disponible mais non déployée, elle-même due à l'absence de double compétence dans l'équipe informatique ». En partant de cet exemple du cours (mise à jour non déployée), reconstruire une chaîne plausible de cinq « pourquoi » successifs qui remonte d'un incident observé (une intrusion réseau) jusqu'à cette cause racine d'absence de double compétence. En quoi la cause racine ainsi obtenue se prête-t-elle mieux à un contrôle *préventif* durable qu'un simple correctif portant sur le seul symptôme immédiat (déployer la mise à jour manquante) ?

- (d) La Loss Distribution Approach « modélise séparément la fréquence des événements de pertes (distribution discrète, le plus souvent une loi de Poisson à un seul paramètre λ) et leur sévérité (distribution continue, asymétrique et à queue épaisse, le plus souvent une loi log-normale), avant de les combiner par convolution [...] pour obtenir la distribution agrégée des pertes », le capital économique « correspond[ant] au 99,9^e centile » de cette distribution agrégée. Le cours ajoute que la théorie des valeurs extrêmes (EVT), qui complète la LDA pour modéliser la queue, « repose sur une hypothèse forte : qu'un mécanisme statistique unique génère l'ensemble des pertes observées et futures [...] rarement vérifiée pour un risque aussi hétérogène que le risque opérationnel ». Expliquer pourquoi le choix d'une loi de Poisson à un seul paramètre pour la fréquence, plus simple que la loi log-normale retenue pour la sévérité, se justifie par la nature même de ce qui est compté (un nombre d'événements) par opposition à ce qui est mesuré (un montant de perte, continu et asymétrique). En quoi l'hétérogénéité du risque opérationnel, que le cours invoque lui-même pour disqualifier l'hypothèse d'un « mécanisme statistique unique » de l'EVT, est-elle déjà, en amont, la raison pour laquelle la LDA sépare fréquence et sévérité plutôt que de modéliser directement les pertes par une loi jointe unique ? Enfin, les modèles AMA, bien que remplacés depuis 2023, « combinaient quatre inputs : les données de pertes internes (ILD) et externes (ELD), qui informent le passé, et les données de scénarios (SD) et les facteurs d'environnement d'affaires et de contrôle interne (BEICF), qui informent le futur prospectif ». Classer ces quatre inputs selon qu'ils sont tournés vers le passé ou vers le futur, et expliquer pourquoi une modélisation du capital économique qui ne s'appuierait que sur les deux premiers (ILD, ELD) resterait structurellement incomplète.

2 Exercice cumulatif (chapitre 3, chapitre 2, chapitre 1, introduction)

Exercice 4 — La mesure et l'évaluation à la lumière du chapitre 2, du chapitre 1 et de l'introduction

- (a) Le chapitre 2 range la RCSA parmi les outils de l'identification ascendante, précisant qu'elle est « un exercice mené en atelier, où les participants réfléchissent collectivement aux risques et contrôles de leur activité — méthode qui mêle en pratique identification et évaluation ». Ce chapitre définit précisément le second de ces deux usages : la RCSA « évalue la probabilité et l'impact d'un risque avant l'effet des contrôles en place (risque inhérent) et après (risque résiduel) ». Montrer que ces deux citations, mises bout à bout, décrivent un seul et même exercice observé à deux moments distincts de son usage dans le cours : le chapitre 2 la présente au moment où elle sert encore à *repérer* des risques, ce chapitre au moment où elle sert à les *quantifier* en probabilité et en impact. En quel sens la formule du chapitre 2 — « mêle en pratique identification et évaluation » — annonçait-elle déjà, avant même que le cycle en quatre étapes ne les distingue formellement, que la RCSA ne pourrait jamais être un outil purement dédié à une seule de ces deux étapes ? Par ailleurs, le chapitre 2 indique que « l'analyse des pertes internes et externes passées complète [le dispositif d'identification], notamment via les bases de données consortiales telles qu'ORX ». Ce chapitre précise ce que deviennent ces mêmes données externes une fois entrées dans la phase d'évaluation : « les données externes — issues de consortiums comme ORX — complètent la queue [de la distribution des pertes], là où les observations internes sont trop rares ». Montrer que le rôle d'ORX change de nature entre les deux chapitres — de source de *repérage* de types de pertes encore inconnus de l'établissement

(chapitre 2) à source de *calibrage numérique* de la queue d'une distribution statistique (ce chapitre) — et pourquoi ce second usage, bien plus exigeant en qualité et en comparabilité des données, n'aurait aucun sens à mobiliser sans le premier.

- (b) La carte de chaleur de ce chapitre « combine probabilité et impact en un code couleur [...] », un code que le chapitre indique lui-même refléter « l'appétit pour le risque de l'organisation défini au chapitre 1 ». Le chapitre 1 définit précisément cet appétit comme devant « s'aligner sur les objectifs stratégiques de l'établissement, et se décliner en limites d'exposition, en exigences minimales de contrôle, et en seuils de fréquence et de sévérité des incidents tolérés ». Montrer, couleur par couleur (vert, jaune, ambre, rouge), comment chacune correspond à un positionnement précis par rapport à ces « seuils de fréquence et de sévérité » du chapitre 1 : quelles couleurs de la carte de chaleur situent un risque *dans* les limites d'appétit posées au chapitre 1, et lesquelles signalent un dépassement de ces mêmes limites ? Sans la déclaration d'appétit du chapitre 1, que resterait-il concrètement à la carte de chaleur de ce chapitre pour distinguer le vert de l'ambre ? Ce chapitre indique par ailleurs qu'« un rapport ICAAP type couvre, entre autres, la gouvernance du processus, les méthodologies de mesure du risque, l'identification et la quantification des scénarios, et l'évaluation et la planification du capital ». Le chapitre 1 situe ce même ICAAP comme le nom européen du Pilier 2, « une évaluation qualitative complémentaire, laissant le régulateur ajuster à la hausse le capital calculé en Pilier 1 lorsque le profil de risque de l'établissement le justifie ». Montrer que la « méthode multicritère » de ce chapitre — qui réserve « un capital qui excède à la fois la perte du scénario le plus sévère et celle de deux à quatre scénarios susceptibles de survenir en grappe » — donne un contenu méthodologique concret à ce que le chapitre 1 ne fait que nommer et situer institutionnellement.
- (c) L'introduction définit la résilience opérationnelle comme « la capacité des établissements [...] à prévenir, s'adapter, répondre, se rétablir et apprendre des perturbations opérationnelles », et rapporte que les régulateurs britanniques ont bâti, dès 2018, « un cadre de résilience opérationnelle articulé autour des services opérationnels importants [...] et de niveaux de tolérance à l'impact ». Ce chapitre reprend très exactement ce même couple de notions pour les rendre opérationnelles : « la résilience s'articule autour des services opérationnels importants (IBS) et de tolérances d'impact — le niveau maximal de perturbation tolérable pour un service donné [...] », avant d'ajouter ce que l'introduction ne détaillait pas, une méthode en « sept étapes » allant de l'identification des IBS jusqu'à « documenter et faire approuver par le conseil une auto-évaluation annuelle ». Montrer précisément ce que ce chapitre ajoute à la définition conceptuelle de l'introduction : celle-ci établit *que* la résilience se pense par services et par tolérances plutôt que par processus et délais de reprise (RTO), tandis que ce chapitre établit *comment* on construit, étape par étape, un dispositif qui rend ce choix opérationnel. Une organisation qui s'arrêterait à la seule définition de l'introduction, sans dérouler les sept étapes de ce chapitre, pourrait-elle valablement prétendre avoir adopté une démarche de résilience au sens du régulateur ? Par ailleurs, l'introduction cite le BCBS de façon presque verbatim : « la résilience opérationnelle est un résultat qui bénéficie d'une gestion efficace du risque opérationnel ». Ce chapitre reprend cette même idée dans une formulation quasi identique : « la résilience opérationnelle n'est pas un dispositif séparé : elle est le résultat d'une gestion efficace du risque opérationnel, où l'identification, l'évaluation, l'atténuation et la surveillance des risques travaillent ensemble [...] ». Qu'est-ce que cette répétition, à la toute fin d'un chapitre entier consacré aux techniques de mesure (RCSA, LDA, capital économique), vient prévenir chez un lecteur qui viendrait d'en achever la lecture ?
- (d) L'introduction pose le cycle de gestion des risques en quatre étapes : « l'identification des risques (chapitre 2), leur évaluation en termes de probabilité et d'impact (chapitre 3), leur atténuation par des contrôles ou d'autres mesures (chapitre 4), et leur surveillance continue ». Le chapitre 2 referme sa propre synthèse en désignant explicitement ce chapitre comme la suite de son propre travail : « pour aboutir à un inventaire des risques qui sert de socle à l'étape suivante : l'évaluation, objet du chapitre 3 ». Ce chapitre s'ouvre à son tour en se positionnant très exactement à cet endroit du cycle : « après l'identification, ce chapitre couvre la deuxième étape du cycle : l'évaluation du risque opérationnel ». Montrer que ces trois citations — l'une programmatique (introduction), l'une de clôture (chapitre 2), l'une d'ouverture (ce chapitre)

— décrivent un seul et même passage de relais, formulé à trois moments distincts du cours. En vous appuyant précisément sur ce que le chapitre 2 produit comme « socle » (un inventaire des risques) et sur ce que ce chapitre exige comme matière première pour fonctionner (des données de pertes rattachées à des catégories de risque, une RCSA, des scénarios à décomposer), expliquer pourquoi l'évaluation de ce chapitre serait tout simplement impossible à conduire sans l'inventaire des risques que le chapitre 2 lui transmet : sur quoi porteraient exactement la collecte des données de pertes, la RCSA ou l'analyse de scénarios de ce chapitre si aucun inventaire préalable des risques n'avait été dressé ?

3 Applications en sciences économiques

Exercice 5 — Fréquence, sévérité et capital économique par la LDA, chiffrés

Une banque modélise, par la Loss Distribution Approach, les pertes opérationnelles annuelles d'une ligne d'activité. Sur les dix dernières années, 60 événements de pertes ont été enregistrés au-dessus du seuil de collecte, soit une fréquence annuelle moyenne $\lambda = 6$ événements par an, modélisée par une loi de Poisson. La sévérité de chaque événement est résumée, pour simplifier le calcul, par quatre bandes empiriques :

Bande de sévérité	Perte médiane de la bande (k€)	Probabilité
Bande 1 (0–50 k€)	25	55 %
Bande 2 (50–200 k€)	100	30 %
Bande 3 (200–1 000 k€)	500	12 %
Bande 4 (>1 000 k€, queue)	3 000	3 %

Une simulation de Monte-Carlo de la distribution agrégée des pertes annuelles, combinant cette fréquence et cette sévérité par convolution, produit les centiles suivants (en milliers d'euros) : médiane (50^e centile) 1 100 ; 95^e centile 3 200 ; 99^e centile 6 800 ; 99,9^e centile 18 400.

- Calculer la sévérité moyenne par événement (moyenne des quatre bandes pondérée par leur probabilité), puis la perte annuelle attendue (expected loss) de la ligne d'activité, égale au produit de λ par cette sévérité moyenne.
- Calculer la contribution de chaque bande à la perte annuelle attendue, en pourcentage. La bande de queue (>1 000 k€, 3 % de probabilité seulement) domine-t-elle la perte attendue malgré sa faible probabilité ? En quoi ce résultat illustre-t-il concrètement le caractère « asymétrique et à queue épaisse » de la sévérité mentionné par le cours ?
- Le capital économique correspond au 99,9^e centile de la distribution agrégée des pertes simulées. Rapporter ce capital économique, en multiple, à la perte annuelle attendue calculée au (a). Ce multiple est-il cohérent avec l'idée que le capital économique doit couvrir des pertes « dans 999 années sur 1 000 », bien au-delà de la perte moyenne ?
- La banque complète cette approche LDA par la méthode multicritère de l'ICAAP. Trois scénarios sévères mais plausibles ont été quantifiés : pandémie (12 000 k€), cyberattaque majeure (9 500 k€), défaillance IT critique (6 200 k€) — la banque retenant la grappe pandémie + cyberattaque comme combinaison susceptible de survenir en même temps. Calculer le capital multicritère (le maximum entre la perte du scénario le plus sévère pris isolément et celle de la grappe retenue), et le comparer au capital économique LDA du (c), en points et en pourcentage. Lequel des deux montants la banque devrait-elle retenir pour son ICAAP, et pourquoi ?

Exercice 6 — Tolérances d'impact, points de défaillance uniques et analyse d'impact sur l'activité, chiffrés

Une banque a identifié quatre services opérationnels importants (IBS) et fixé, pour chacun, une tolérance d'impact — la durée maximale de perturbation tolérable, en heures. Un test de scénario sévère mais plausible (panne majeure du système bancaire central) estime la durée effective de

perturbation de chaque IBS si ce scénario devait se matérialiser :

Service opérationnel important (IBS)	Tolérance d'impact (h)	Durée estimée sous le scénario (h)
Paielements domestiques	4	7
Retraits espèces (GAB)	24	18
Courtage en ligne	8	15
Service client (centre d'appels)	12	9

- (a) Pour chaque IBS, calculer l'écart entre la durée estimée sous le scénario et la tolérance d'impact (en heures, puis en pourcentage de la tolérance), et indiquer si la tolérance est dépassée.
- (b) Classer les IBS dont la tolérance est dépassée par ordre décroissant de sévérité relative du dépassement. Selon les sept étapes de la démarche de résilience du cours, laquelle de ces IBS devrait être prioritaire pour « un plan de communication interne et externe » ?
- (c) Le courtage en ligne dépend d'un point de défaillance unique (SPOF) : un prestataire cloud unique. La probabilité annuelle d'une panne majeure de ce prestataire est de 3 %, et son impact — indemnisation des clients et coût réputationnel — est estimé à 45 000 k€. Un investissement en redondance de 2 200 k€ par an ramènerait cette probabilité à 0,5 %. Calculer la perte annuelle attendue avec et sans redondance, la réduction de perte attendue permise par l'investissement, et le bénéfice net de cet investissement (réduction moins coût annuel). Ce seul calcul en perte attendue justifie-t-il l'investissement en redondance ? Qu'affirme le cours au sujet des SPOF qui va au-delà d'un simple calcul de perte attendue ?
- (d) L'analyse d'impact sur l'activité (BIA) du courtage en ligne évalue à 900 k€ le coût financier direct de chaque heure supplémentaire de perturbation. L'appétit pour le risque de la banque tolère un impact financier maximal de 5 000 k€ pour un scénario donné sur cet IBS. Calculer la tolérance d'impact, en heures, qu'impliquerait cet appétit pour le risque, et la comparer à la tolérance de 8 heures effectivement fixée pour cet IBS (donnée dans le tableau ci-dessus). La tolérance actuellement fixée est-elle plus ou moins conservatrice que ce que l'appétit pour le risque justifierait, et quelle action cela suggère-t-il concrètement à la banque ?